FARMAPS

Manual de módulos de ciberseguridad, ethical hacking y operación ITIL

JUAN DAVID CARDOZO PRADA

CIBERSEGURIDAD Y ETHICAL HACKING

[NOMBRE DEL DOCENTE]

UNIVERSIDAD LIBRE

INGENIERÍA DE SISTEMAS

2026

Introducción

Este documento presenta el manual técnico y de usuario de las funcionalidades de ciberseguridad, ethical hacking y gestión de servicios con enfoque ITIL que se implementaron en la plataforma Farmaps para su despliegue independiente en el proyecto de Firebase Farmaps-Ciberseguridad (https://farmaps-ciberseguridad.web.app). A diferencia del manual general del sistema base (Cardozo Prada, 2026), este documento describe exclusivamente los módulos nuevos, el endurecimiento de seguridad y los controles añadidos para esta asignatura.

La adaptación transforma el comparador académico en un servicio digital gestionado bajo el ciclo de vida ITIL (Estrategia, Diseño, Transición, Operación y Mejora continua), incorporando un canal público de atención de reportes e incidentes, una página de transparencia sobre la postura de seguridad y privacidad, una mesa de servicio administrativa, una bitácora inmutable de auditoría con seguimiento de Acuerdos de Nivel de Servicio (ANS) y defensas activas contra ataques de fuerza bruta, secuestro de sesión e inyección de código.

Alcance de la implementación de ciberseguridad e ITIL

Las mejoras implementadas abarcan cuatro frentes complementarios: (a) en el sitio público se añadieron las pantallas P06 (Soporte y reportes ITIL) y P07 (Seguridad y privacidad), el botón de reporte contextual en el detalle de oferta (P05) y el archivo estándar de divulgación responsable /.well-known/security.txt (RFC 9116); (b) en el panel de administración se incorporaron las pantallas A07 (Mesa de servicio ITIL) y A08 (Bitácora de auditoría, controles y metas ANS); (c) en los módulos de sesión y acceso se integraron el bloqueo progresivo anti-fuerza bruta y el cierre automático por inactividad de 15 minutos; y (d) en el servidor se reforzaron las reglas de Cloud Firestore, las cabeceras HTTP de seguridad y las pruebas automatizadas de permisos.

Tabla 1

Entorno de despliegue de la versión Farmaps-Ciberseguridad

Elemento	**Valor implementado**
Nombre del proyecto en Firebase	Farmaps-Ciberseguridad (independiente del proyecto original FARMAPS)
Identificador del proyecto (Project ID)	farmaps-ciberseguridad
URL pública desplegada (HTTPS / HSTS)	https://farmaps-ciberseguridad.web.app
Rutas públicas nuevas	/P06/ (alias /soporte), /P07/ (alias /seguridad) y /.well-known/security.txt
Módulos administrativos nuevos	/A07/ (Mesa de servicio ITIL) y /A08/ (Bitácora de auditoría y metas ANS)
Nuevas colecciones en Cloud Firestore	reportes (tickets P1 a P4) y auditoria (registro inmutable de solo anexado)

Convenciones utilizadas

Al igual que en el manual de usuario original, los nombres de botones, enlaces, listas desplegables y mensajes del sistema se escriben entre comillas con su texto exacto. Los nuevos módulos públicos se identifican con los códigos P06 y P07, y los nuevos módulos administrativos con los códigos A07 y A08.

Acceso a los nuevos módulos implementados

Navegación pública hacia soporte y seguridad

En la barra superior de todas las pantallas públicas (P01 a P07) se agregaron los enlaces "Soporte y reportes" y "Seguridad y privacidad", los cuales permiten acceder en cualquier momento al canal de atención ITIL (P06) y al modelo de seguridad del servicio (P07) sin necesidad de crear una cuenta ni iniciar sesión. En la Figura 1 se observa la barra de navegación actualizada en el sitio publicado.

Figura 1

Barra de navegación pública con los enlaces Soporte y reportes (P06) y Seguridad y privacidad (P07)



Nota. Captura tomada de https://farmaps-ciberseguridad.web.app.

Navegación administrativa y controles de acceso en A01

En la barra superior del panel administrativo (A02 a A08) se añadieron las pestañas "Reportes ITIL" (A07) y "Auditoría y ANS" (A08). Además, el validador de rutas destinoAdministrativo() en compartido/sesion.js se amplió con la expresión regular /^A0[2-9]$/ para permitir el retorno seguro tras iniciar sesión en A01 y bloquear redirecciones abiertas hacia dominios externos.

Roles, permisos y endurecimiento de seguridad

La adaptación mantiene los dos roles del sistema (visitante y administrador), pero aplica el principio de mínimo privilegio y denegación por defecto sobre las nuevas colecciones de operación ITIL y trazabilidad. En la Tabla 2 se detalla la matriz de permisos implementada en firestore.rules para los nuevos recursos.

Tabla 2

Matriz de permisos de los nuevos recursos de ciberseguridad e ITIL

Recurso u operación implementada	**Visitante (sin cuenta)**	**Administrador autorizado**
Consultar la página de seguridad y privacidad (P07) y /.well-known/security.txt	Permitido	Permitido
Crear un reporte de soporte o incidente en la colección /reportes (P06)	Permitido (con validación estricta de campos, prioridad y hora del servidor)	Permitido
Leer o listar los tickets de la colección /reportes (A07)	Denegado (403 Forbidden)	Permitido
Actualizar el estado, prioridad o nota interna de un reporte en /reportes (A07)	Denegado	Permitido (el texto y el contacto originales son inmutables)
Eliminar reportes de la colección /reportes	Denegado	Denegado (prohibido en reglas)
Crear entradas en la bitácora /auditoria al modificar el catálogo o gestionar tickets	Denegado	Permitido (solo con su propio UID y request.time)
Leer y exportar la bitácora /auditoria y los indicadores ANS (A08)	Denegado	Permitido
Modificar o eliminar entradas existentes de la bitácora /auditoria	Denegado	Denegado (registro de solo anexado)

Controles de seguridad y mitigación de vulnerabilidades implementados

Durante la adaptación para la asignatura de Ciberseguridad y Ethical Hacking se realizó una auditoría sobre el código fuente original y se implementaron seis controles técnicos de defensa en profundidad:

- **Cabeceras HTTP de seguridad en Firebase Hosting (firebase.json):** Se configuraron globalmente las cabeceras Content-Security-Policy (CSP) con lista blanca de orígenes, Strict-Transport-Security (HSTS por 1 año con subdominios), X-Frame-Options: DENY contra ataques de clickjacking, X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, Permissions-Policy (restringiendo cámara, micrófono, USB y pagos) y Cross-Origin-Opener-Policy. En las rutas administrativas (/A0*/**) se añadieron Cache-Control: no-store y X-Robots-Tag: noindex, nofollow.
- **Reducción de superficie de ataque y compatibilidad estricta con CSP:** Se excluyó la carpeta administrativa carga-datos/** del despliegue público en firebase.json y se reemplazó el enlace javascript:history.back() en 404.html por una ruta declarativa hacia /P06/, eliminando la ejecución de código en línea.
- **Bloqueo progresivo contra ataques de fuerza bruta (compartido/sesion.js y A01):** Además del límite por dirección IP de Firebase Authentication, el cliente registra los intentos fallidos de inicio de sesión y bloquea el formulario tras 5 fallos consecutivos durante 1 minuto, duplicando el tiempo en cada intento adicional (1, 2, 4, 8 y hasta 15 minutos) con un contador regresivo en pantalla.
- **Cierre automático de sesión por inactividad (compartido/admin.js):** En todas las pantallas administrativas (A02 a A08) se supervisan los eventos de interacción del usuario; tras 15 minutos sin actividad, el sistema registra el evento sesion_expirada en la

bitácora, cierra la sesión en Firebase Authentication y redirige a A01/index.html?expirada=1.

- **Bitácora de auditoría inmutable (compartido/auditoria.js y firestore.rules):** Cada inicio o cierre de sesión, cada creación o edición en A03–A06 y cada cambio de estado en A07 escribe un documento en la colección /auditoria con el UID, correo, módulo, identificador del documento, detalle y marca de tiempo del servidor. Las reglas de Firestore prohíben actualizar o borrar cualquier registro de esta colección.
- **Privacidad por diseño y preparación de Firebase App Check (compartido/firebase.js):** Se retiró el módulo Google Analytics (firebase-analytics.js) para garantizar que la consulta pública anónima no envíe identificadores de navegación a terceros, y se dejó integrado el cargador de Firebase App Check con proveedor reCAPTCHA v3.

Módulos y funcionalidades implementados

En la Tabla 3 se resumen los módulos y componentes que fueron creados o ampliados en la plataforma para cubrir los procesos de operación del servicio ITIL y los requerimientos de ciberseguridad.

Tabla 3

Nuevas pantallas y componentes añadidos a Farmaps-Ciberseguridad

Código / ruta	**Nombre del módulo**	**Función implementada**
P05 (/detalle)	Detalle de oferta (ampliado)	Incorpora el botón "Reportar dato incorrecto", que abre P06 precargando automáticamente el identificador exacto de la oferta o presentación.
P06 (/soporte)	Canal público de soporte y reportes ITIL	Permite a cualquier usuario registrar reportes de precios incorrectos, datos de farmacias, fallas técnicas o vulnerabilidades de seguridad con prioridad automática P1–P4.
P07 (/seguridad)	Seguridad del servicio, privacidad y nivel ITIL	Explica públicamente el Nivel Alto de seguridad, la tríada CIA, el inventario de activos, los controles activos, la matriz de responsabilidades y la divulgación responsable.
/.well-known/security.txt	Política estándar RFC 9116	Archivo de texto plano con el canal oficial de contacto, vigencia e idioma para reportar hallazgos de seguridad de manera ética.
A01 (/A01/)	Acceso administrativo (endurecido)	Muestra el reloj de bloqueo progresivo ante intentos fallidos y el aviso de sesión cerrada por inactividad de 15 minutos.
A07 (/A07/)	Mesa de servicio y reportes ITIL	Permite al administrador filtrar tickets, verificar el cumplimiento del ANS de 1 día hábil, registrar la nota de verificación y cambiar el estado o prioridad.
A08 (/A08/)	Bitácora de auditoría, seguridad y metas ANS	Calcula en vivo las tres metas mensuales del piloto ITIL, muestra la bitácora inmutable /auditoria con exportación JSON y verifica los controles activos.

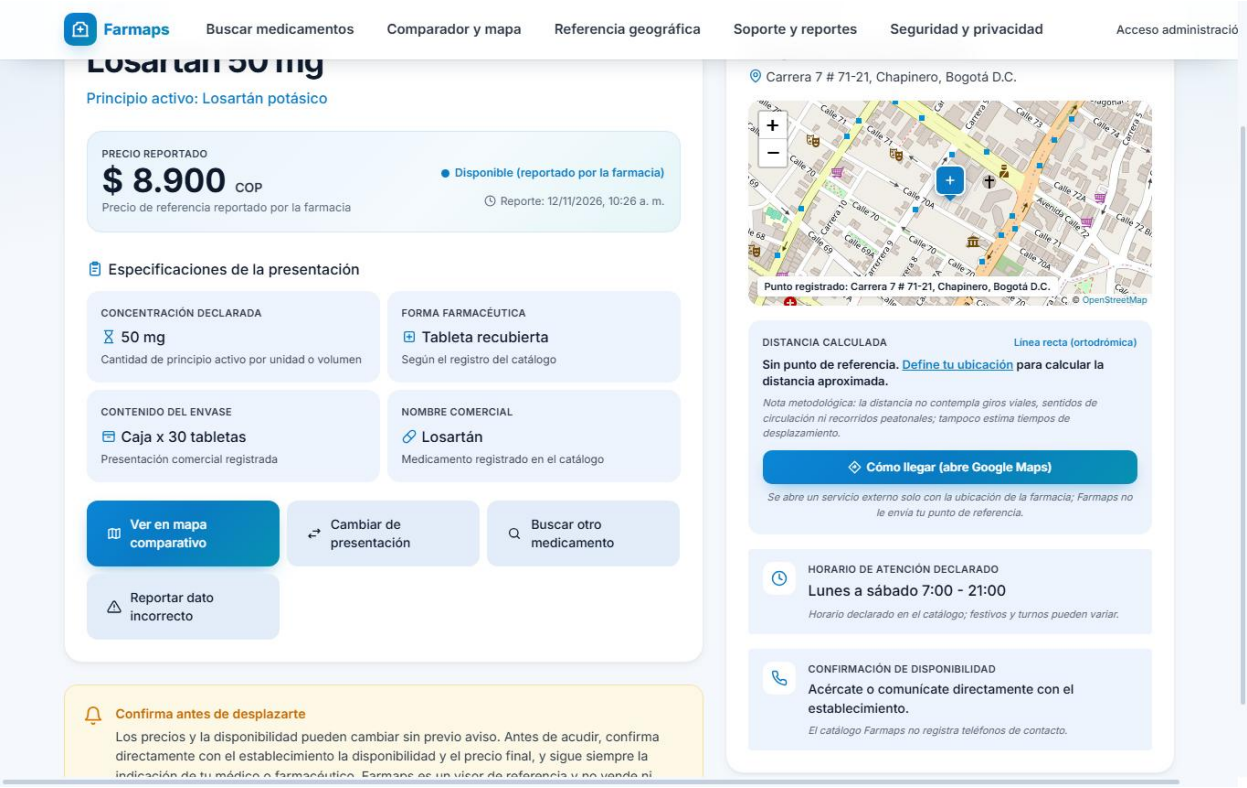
Botón de reporte contextual en Detalle de oferta (P05)

En la pantalla de detalle de una oferta (P05) se añadió la acción "Reportar dato incorrecto" dentro del bloque de botones de la tarjeta principal. Al presionarlo, el sistema

redirige a la pantalla P06 enviando en la dirección el tipo de reporte precio_incorrecto y el código exacto de la oferta consultada (por ejemplo, f01__losartan-50-mg-caja-x-30-tabletas__COP), evitando que el usuario tenga que copiar o escribir códigos manualmente.

Figura 2

Detalle de oferta (P05) con el nuevo botón Reportar dato incorrecto



Nota. El enlace vincula automáticamente el código de la oferta con el formulario de soporte P06.

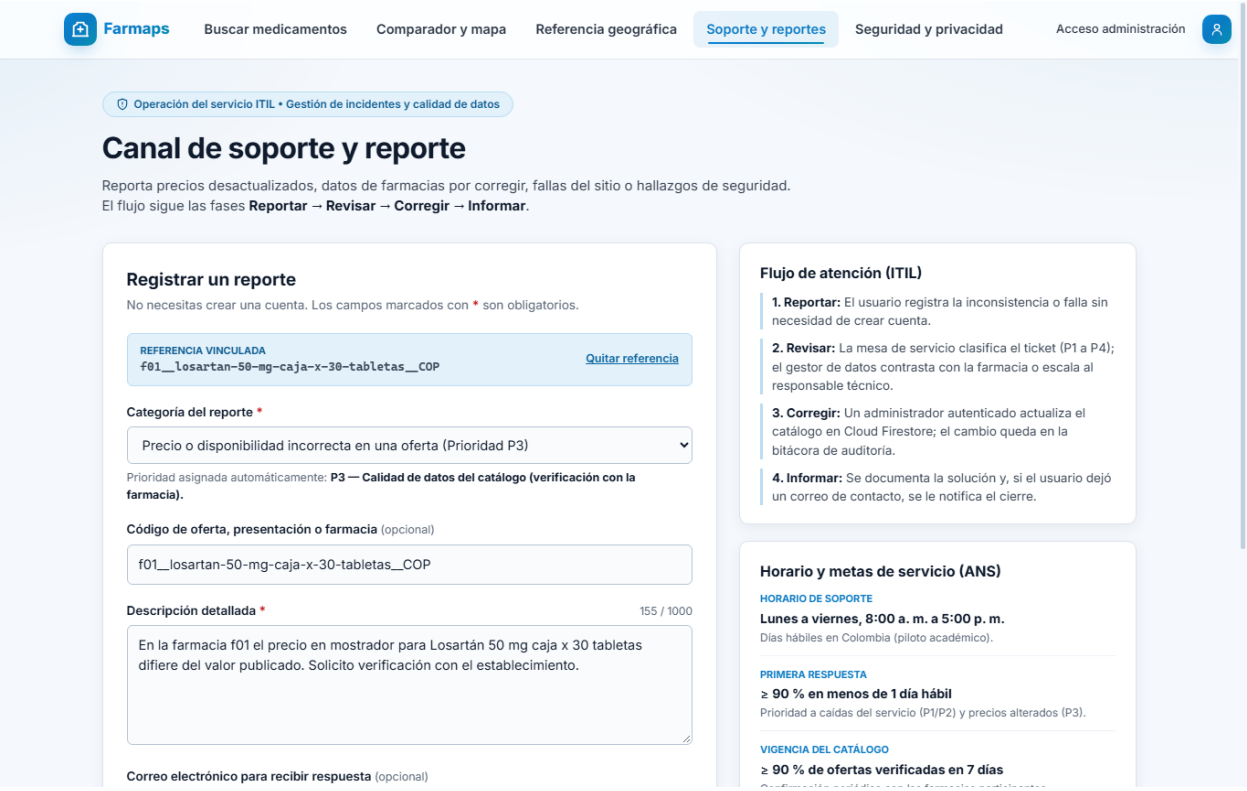
Canal público de soporte y reporte de incidentes (P06)

La pantalla P06 materializa el flujo de atención propuesto en el diseño del servicio con enfoque ITIL: Reportar → Revisar → Corregir → Informar. Está dividida en dos columnas: a la izquierda se encuentra el formulario de registro sin cuenta y a la derecha se presentan las cuatro etapas del flujo ITIL, el horario de atención (lunes a viernes de 8:00 a. m. a 5:00 p. m.) y los compromisos de nivel de servicio.

Al seleccionar la categoría del reporte, el sistema asigna automáticamente la prioridad ITIL: P1 para incidentes o vulnerabilidades de seguridad, P2 para fallas técnicas de la aplicación, P3 para inconsistencias de precio, disponibilidad o datos de farmacia, y P4 para consultas generales o sugerencias. El formulario incluye un aviso de protección de datos sensibles para evitar que las personas envíen fórmulas médicas o historias clínicas, un campo señuelo oculto (honeypot) contra bots y una espera mínima de 45 segundos entre envíos desde la misma pestaña.

Figura 3

Pantalla P06: formulario de soporte ITIL con referencia vinculada y asignación automática de prioridad



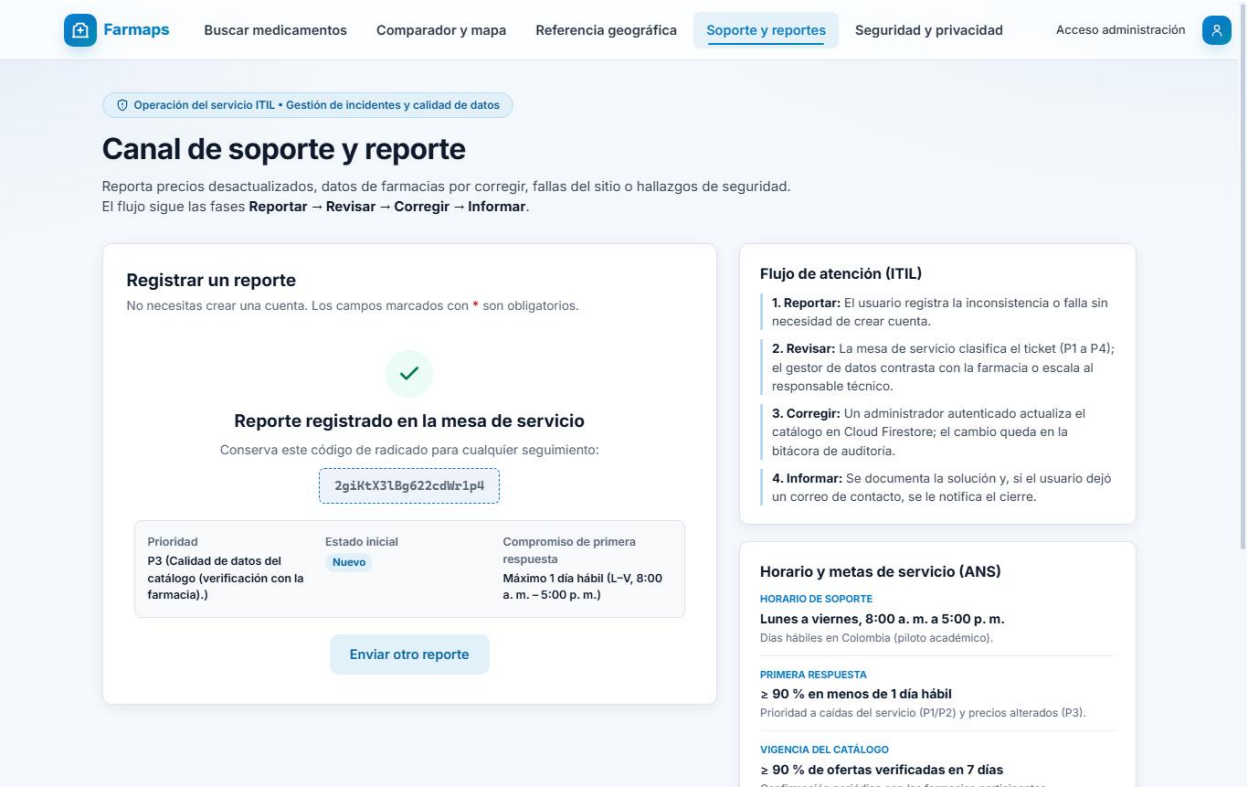
Nota. Captura del formulario público antes de enviar el reporte.

Una vez enviado el formulario, Cloud Firestore valida en el servidor que la descripción tenga entre 15 y 1000 caracteres, que el estado inicial sea "nuevo", que la prioridad coincida con

la categoría y que la fecha corresponda a request.time. El sistema muestra entonces el recuadro de confirmación con el código único de radicado, como se aprecia en la Figura 4.

Figura 4

Confirmación de radicado en P06 tras registrar un reporte en Cloud Firestore



Nota. El usuario recibe el código único del ticket, la prioridad asignada y el compromiso de respuesta.

Seguridad del servicio, privacidad y nivel ITIL (P07)

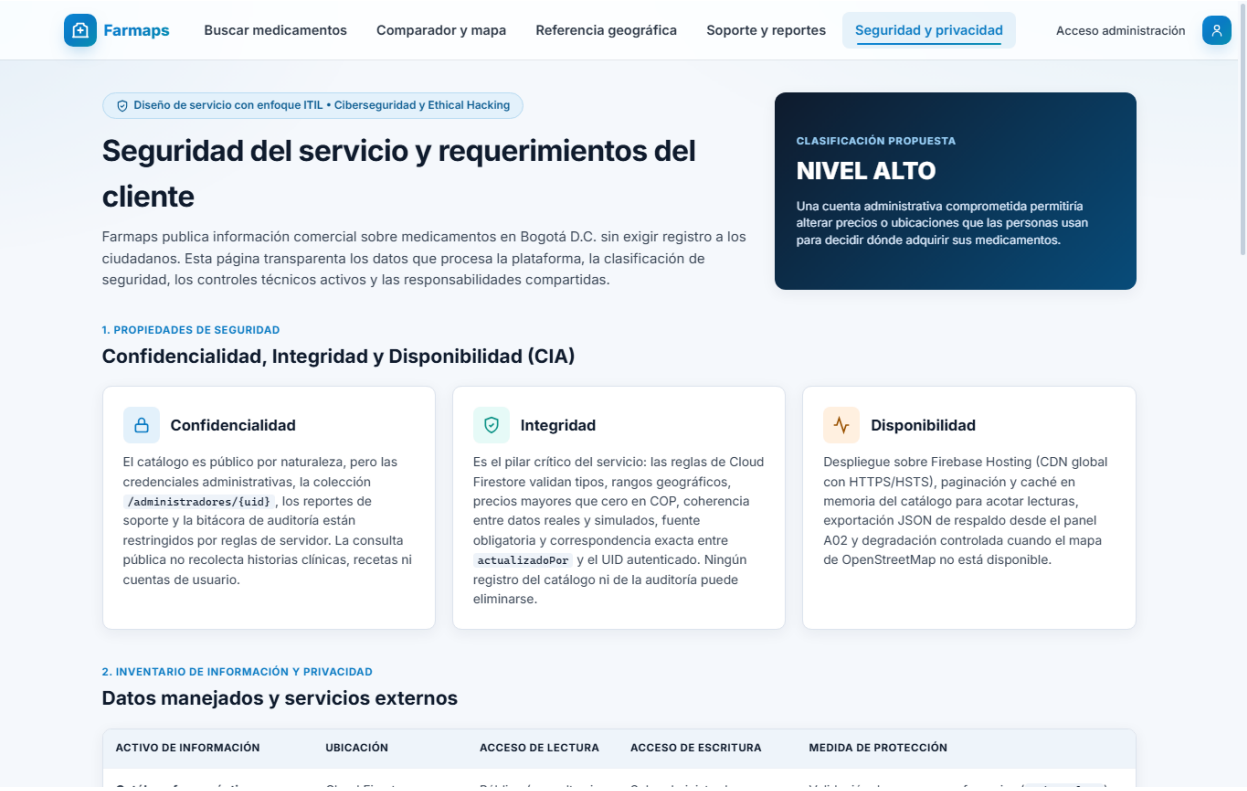
La pantalla P07 presenta de forma transparente los requerimientos de seguridad del servicio exigidos por la guía de diseño ITIL. En su encabezado destaca la clasificación propuesta de Nivel Alto, justificada porque la alteración no autorizada de precios o ubicaciones afectaría las decisiones de compra de medicamentos de los ciudadanos.

El módulo desarrolla cinco secciones: (1) las propiedades de Confidencialidad, Integridad y Disponibilidad (tríada CIA); (2) la tabla de inventario de activos de información y servicios

externos, dejando explícito que el punto de referencia se guarda únicamente en sessionStorage; (3) los cuatro bloques de defensa en profundidad implementados; (4) la matriz de responsabilidades compartidas entre la empresa prestadora, las farmacias participantes y la persona usuaria; y (5) la política de divulgación responsable de vulnerabilidades vinculada al archivo /.well-known/security.txt.

Figura 5

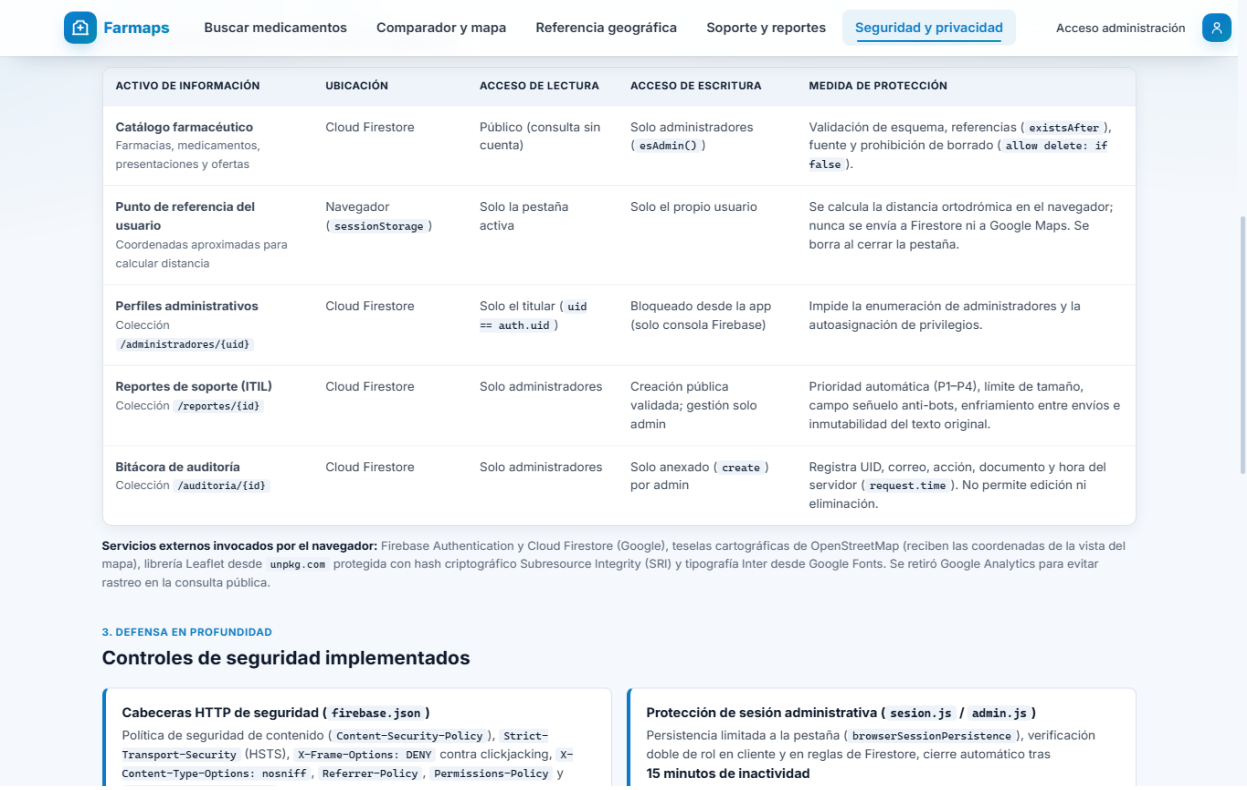
Pantalla P07: clasificación de seguridad de Nivel Alto, tríada CIA e inventario de activos de información



Nota. Sección superior del módulo público de seguridad y privacidad.

Figura 6

Pantalla P07: controles técnicos de defensa en profundidad, responsabilidades compartidas y divulgación ética



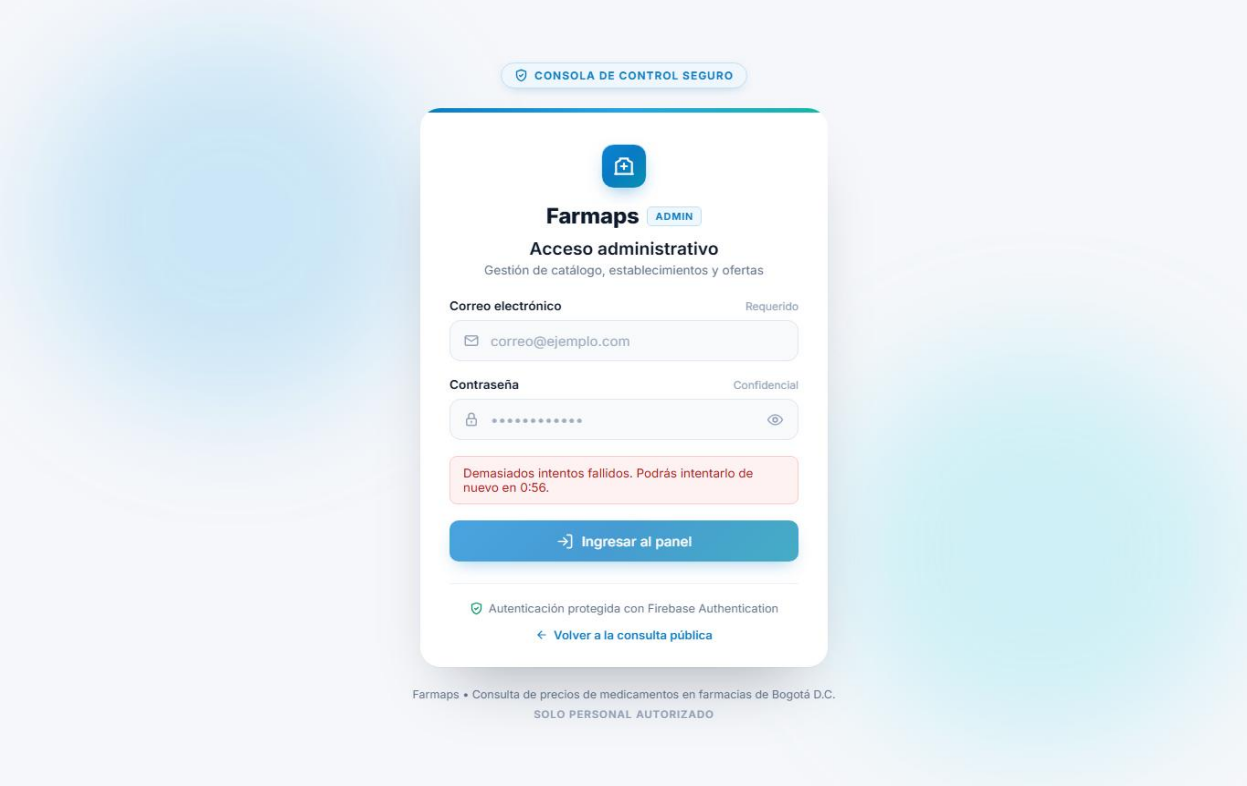
Nota. Sección inferior de P07 con acceso directo al reporte de vulnerabilidades P1 y al archivo security.txt.

Controles de protección de sesión en el acceso administrativo (A01)

La pantalla A01 conserva el diseño del acceso administrativo original pero incorpora dos mecanismos de seguridad activa. El primero es el bloqueo progresivo local tras cinco intentos fallidos de inicio de sesión, el cual deshabilita el botón "Ingresar al panel" y muestra un reloj regresivo en vivo (Figura 7). El segundo es la desconexión automática tras 15 minutos sin actividad en cualquiera de los módulos administrativos, que redirige a A01 y muestra el aviso informativo correspondiente (Figura 8).

Figura 7

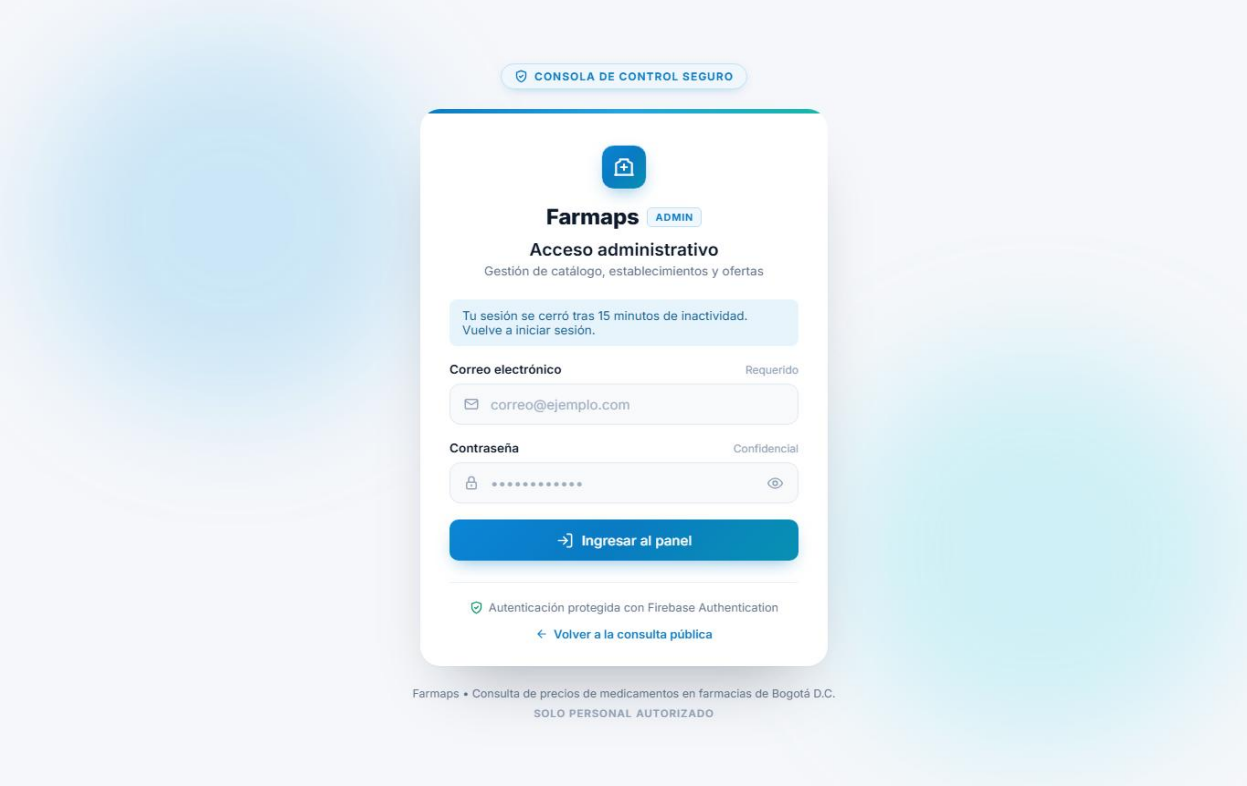
Bloqueo progresivo activo en A01 tras cinco intentos fallidos de inicio de sesión



Nota. El botón de envío permanece deshabilitado hasta que finaliza la cuenta regresiva.

Figura 8

Aviso en A01 tras el cierre automático de la sesión administrativa por 15 minutos de inactividad



Nota. Además del aviso en pantalla, el evento queda registrado en la colección /auditoria.

Mesa de servicio y gestión de reportes ITIL (A07)

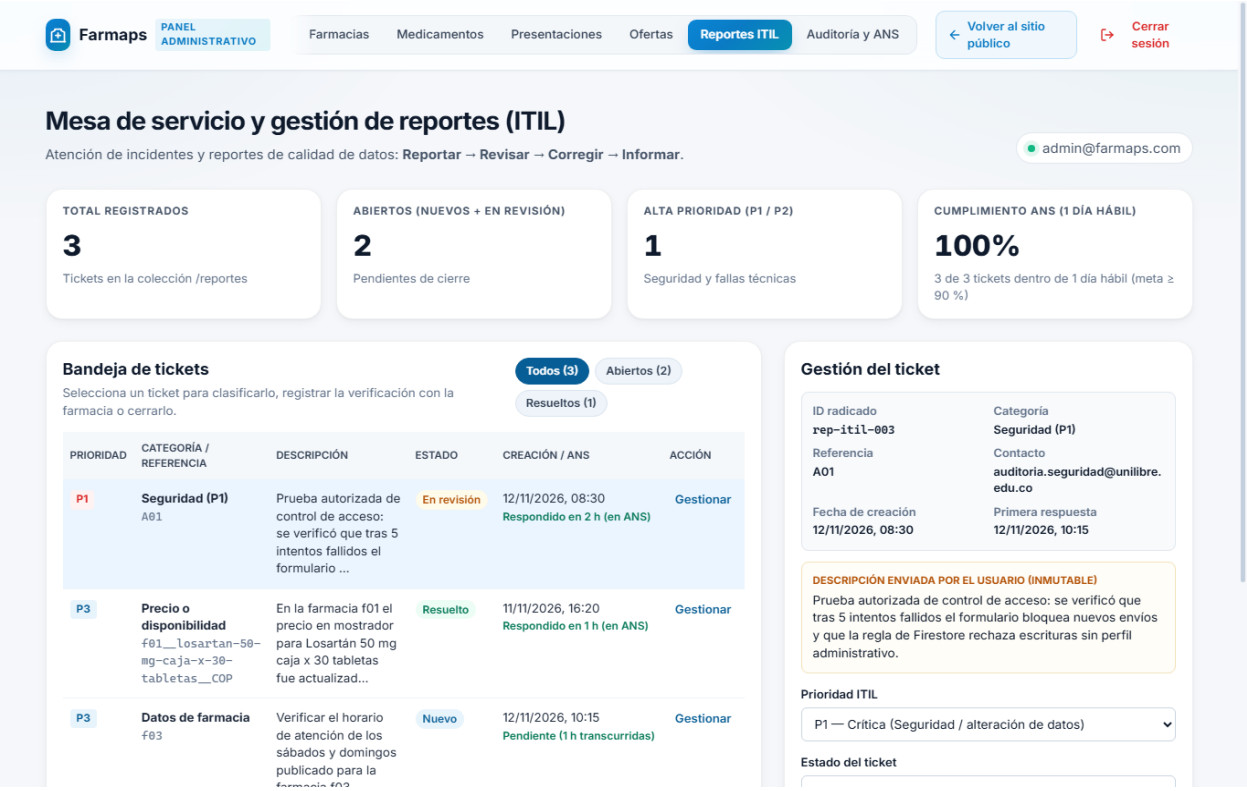
El módulo administrativo A07 permite al responsable del servicio y al gestor de datos atender los reportes enviados por los usuarios desde P06. En la parte superior muestra cuatro tarjetas de indicadores: "Total registrados", "Abiertos (Nuevos + En revisión)", "Alta prioridad (P1 / P2)" y "Cumplimiento ANS (1 día hábil)".

En la parte inferior izquierda se encuentra la bandeja de tickets con filtros por estado ("Todos", "Abiertos" y "Resueltos"), donde cada fila indica la prioridad (P1 a P4), la categoría, la referencia del catálogo, el extracto de la descripción, el estado actual y el semáforo del ANS de primera respuesta. Al seleccionar un ticket, el panel derecho "Gestión del ticket" muestra los metadatos completos y la descripción original del usuario en un recuadro protegido (inmutable por regla de servidor), permitiendo actualizar la prioridad, el estado ("Nuevo", "En revisión", "Resuelto" o "Descartado") y la nota interna de verificación. Al pasar por primera vez un ticket a

revisión o cierre, el sistema registra automáticamente la marca de tiempo fechaPrimeraRespuesta en el servidor.

Figura 9

Módulo administrativo A07: Mesa de servicio y gestión de reportes ITIL con edición de un ticket P1



Nota. La descripción enviada por el ciudadano es inmutable; el administrador solo modifica los campos de gestión.

Bitácora de auditoría, postura de seguridad y metas ANS (A08)

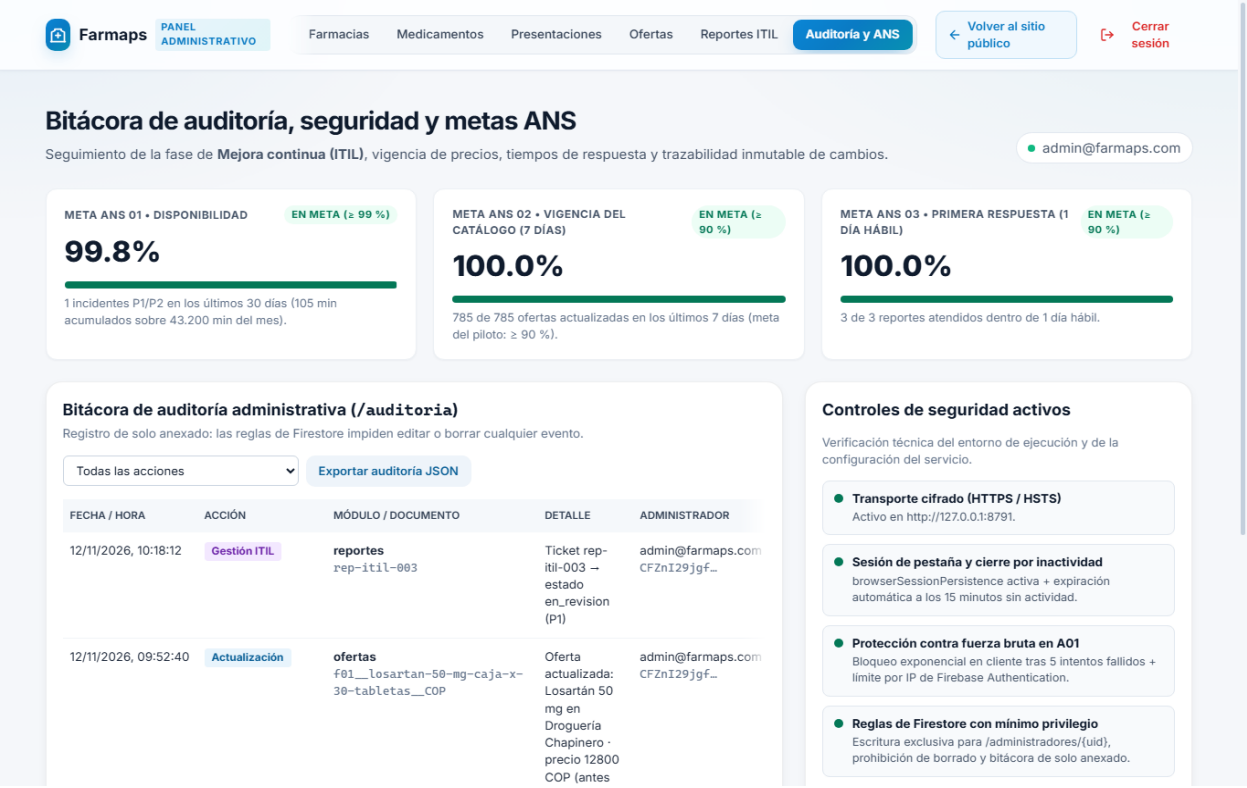
El módulo administrativo A08 integra la fase de Mejora continua de ITIL con la supervisión de seguridad. En la franja superior presenta las tres tarjetas de metas mensuales del piloto definidas en el diseño del servicio: (1) "Meta ANS 01 • Disponibilidad" (meta mayor o igual a 99 %, calculada como minutos disponibles sobre los 43.200 minutos del mes descontando la duración de incidentes P1 y P2); (2) "Meta ANS 02 • Vigencia del catálogo (7 días)" (meta

mayor o igual a 90 % de ofertas actualizadas en los últimos siete días); y (3) "Meta ANS 03 • Primera respuesta (1 día hábil)" (meta mayor o igual a 90 % de tickets atendidos en menos de 24 horas).

En la columna inferior izquierda se visualiza la tabla de la colección /auditoria ordenada de la acción más reciente a la más antigua, con filtro por tipo de evento ("Inicios de sesión", "Cierres de sesión", "Sesiones expiradas por inactividad", "Creación de registros", "Actualización de registros" y "Gestión de reportes ITIL") y el botón "Exportar auditoría JSON" para conservar respaldos externos. A la derecha se muestra la lista de verificación de los seis controles de seguridad activos.

Figura 10

Módulo administrativo A08: indicadores mensuales ANS, bitácora de auditoría inmutable y controles activos



Nota. Vista completa de A08 con las tres metas del piloto ITIL en cumplimiento y los eventos de auditoría.

Procedimientos paso a paso

Reportar un precio incorrecto desde el detalle de una oferta

1. En el comparador (P03), abrir el detalle de la oferta que se desea reportar haciendo clic en "Ver detalle" (P05).
2. En el bloque de acciones de la oferta, hacer clic en el botón "Reportar dato incorrecto".
3. Verificar que en la pantalla P06 aparezca el recuadro "Referencia vinculada" con el código de la oferta y la categoría "Precio o disponibilidad incorrecta en una oferta (Prioridad P3)".
4. Escribir en el campo "Descripción detallada" qué diferencia se encontró en la farmacia (mínimo 15 caracteres), sin incluir datos clínicos ni fórmulas médicas.
5. De forma opcional, escribir un correo electrónico en "Correo electrónico para recibir respuesta" si se desea recibir notificación del cierre.
6. Presionar el botón "Enviar reporte" y conservar el código de radicado que muestra la pantalla de confirmación.

Reportar un incidente o hallazgo de seguridad (divulgación responsable)

1. Ingresar a "Seguridad y privacidad" (P07) en la barra superior y desplazarse hasta la sección "5. Ethical Hacking y mejora continua", o abrir directamente /.well-known/security.txt.
2. Hacer clic en el botón "Reportar hallazgo de seguridad", el cual abre P06 con la categoría preseleccionada "Incidente o vulnerabilidad de seguridad (Prioridad P1)".
3. Indicar en "Código de oferta, presentación o farmacia" el módulo evaluado (por ejemplo, A01 o P03) y describir los pasos para reproducir el hallazgo realizado con datos de prueba.

4. Hacer clic en "Enviar reporte". El ticket quedará marcado con prioridad crítica P1 para escalamiento inmediato al responsable técnico.

Atender y cerrar un ticket en la mesa de servicio (A07)

1. Iniciar sesión como administrador en A01 y hacer clic en la pestaña "Reportes ITIL" (A07) de la barra administrativa.
2. En la "Bandeja de tickets", usar los botones "Todos", "Abiertos" o "Resueltos" para localizar el reporte y hacer clic sobre su fila o en el botón "Gestionar".
3. Revisar en el panel derecho "Gestión del ticket" la referencia vinculada, el contacto y el recuadro "Descripción enviada por el usuario (inmutable)".
4. Cambiar el campo "Estado del ticket" a "En revisión (verificando con farmacia / técnico)", escribir el avance en "Nota de verificación / resolución" y presionar "Guardar gestión". Esto registra automáticamente la hora de primera respuesta para el indicador ANS.
5. Si el reporte corresponde a un dato del catálogo, abrir el módulo respectivo (A03 a A06), corregir el dato y regresar a A07.
6. Cambiar el estado del ticket a "Resuelto (corregido e informado)", documentar la solución aplicada y presionar "Guardar gestión". El cambio queda registrado de forma inmutable en la bitácora /auditoria.

Consultar las metas ANS y exportar la bitácora de auditoría (A08)

1. En el panel administrativo, hacer clic en la pestaña "Auditoría y ANS" (A08).
2. Revisar en la parte superior el porcentaje y el estado ("En meta" o "Por validar") de las tres tarjetas ANS: Disponibilidad mensual (≥ 99 %), Vigencia del catálogo en 7 días (≥ 90 %) y Primera respuesta en 1 día hábil (≥ 90 %).

3. En la sección "Bitácora de auditoría administrativa (/auditoria)", seleccionar en la lista desplegable el tipo de acción que se desea auditar (por ejemplo, "Gestión de reportes ITIL" o "Sesiones expiradas por inactividad").

4. Hacer clic en el botón "Exportar auditoría JSON" para descargar en el equipo el archivo farmaps-auditoria-AAAA-MM-DD.json con todos los eventos firmados por UID y fecha del servidor.

Validaciones y mensajes de error de los nuevos módulos

En la Tabla 4 se documentan todas las validaciones y los mensajes de control agregados en los módulos P06, A01, A07 y A08, junto con su causa y la acción recomendada.

Tabla 4

Mensajes de validación y control en los módulos de ciberseguridad e ITIL

Módulo	**Mensaje mostrado por el sistema**	**Causa**	**Qué hacer**
P06	"Describe el reporte con al menos 15 caracteres para poder verificarlo."	La descripción del reporte tiene menos de 15 caracteres.	Ampliar la explicación indicando qué dato o falla se encontró.
P06	"Usa solo letras, números, guiones (-) o guiones bajos (_), máximo 200 caracteres."	El campo de referencia contiene espacios o símbolos especiales no permitidos por la regla de Firestore.	Escribir únicamente el identificador del registro o dejar el campo vacío.
P06	"Escribe un correo electrónico válido o deja el campo vacío."	El correo de contacto no tiene formato usuario@dominio.ext.	Corregir el correo o borrarlo para enviar el reporte de forma anónima.
P06	"Por seguridad, espera X segundos antes de enviar otro reporte."	Se intentó enviar otro reporte antes de cumplirse los 45 segundos de enfriamiento.	Esperar a que finalice el tiempo indicado antes de enviar un nuevo ticket.
A01	"Demasiados intentos fallidos. Podrás intentarlo de nuevo en M:SS."	Se registraron 5 o más intentos fallidos de inicio de sesión desde el navegador.	Esperar a que termine la cuenta regresiva y verificar las credenciales antes de reintentar.
A01	"Tu sesión se cerró tras 15 minutos de inactividad. Vuelve a iniciar sesión."	El panel administrativo permaneció abierto sin interacción durante 15 minutos.	Iniciar sesión nuevamente en A01 para continuar trabajando.
A07	"Reporte <ID> actualizado a '<Estado>'."	La gestión del ticket cumplió las reglas de Firestore y se guardó junto con su entrada en /auditoria.	Ninguna; el indicador ANS se actualiza de inmediato en A07 y A08.

Verificación automatizada de reglas de seguridad (Ethical Hacking)

El script DOCUMENTACIÓN/Evidencias_Respaldos/scripts/permisos.py fue ampliado con los casos S17 a S22 para comprobar mediante peticiones HTTP REST directas contra Cloud Firestore que ningún atacante pueda leer reportes ajenos, manipular prioridades ni alterar la bitácora de auditoría. La Tabla 5 resume los nuevos casos incorporados.

Tabla 5

Nuevos casos de prueba de permisos y seguridad en permisos.py (S17 a S22)

Caso	**Prueba ejecutada contra la API REST de Firestore**	**Resultado esperado**
S17	Visitante sin sesión intenta leer o listar la colección /reportes (GET /reportes).	403 Forbidden (bloqueado)
S18	Visitante intenta crear un reporte de tipo seguridad manipulando la prioridad a P4 o sin hora del servidor.	400 / 403 (rechazado por reporteNuevoValido)
S19	Visitante intenta enviar un reporte con descripción menor a 15 caracteres.	400 / 403 (rechazado)
S20	Visitante sin sesión intenta leer la bitácora administrativa /auditoria (GET /auditoria).	403 Forbidden (bloqueado)
S21	Visitante intenta inyectar una entrada falsa en /auditoria (POST /auditoria).	403 Forbidden (bloqueado)
S22	Administrador autenticado intenta eliminar un registro de /auditoria (DELETE /auditoria/{id}).	403 Forbidden (inmutabilidad garantizada)

Glosario de ciberseguridad e ITIL

Tabla 6

Términos de ciberseguridad y gestión del servicio utilizados en el manual

Término	**Definición en Farmaps-Ciberseguridad**
ANS (SLA)	Acuerdo de Nivel de Servicio. Compromiso medible de disponibilidad (≥ 99 %), vigencia de precios en 7 días (≥ 90 %) y primera respuesta a reportes en 1 día hábil (≥ 90 %).
Bitácora de solo anexado	Colección /auditoria en la que solo se permite crear registros nuevos (create) y está prohibido editar (update) o borrar (delete), garantizando la trazabilidad y el no repudio.
CSP (Content-Security-Policy)	Cabecera HTTP configurada en firebase.json que restringe desde qué dominios el navegador puede cargar scripts, hojas de estilo, fuentes, imágenes y conexiones.
Divulgación responsable (RFC 9116)	Práctica ética de reportar vulnerabilidades al titular del servicio mediante /.well-known/security.txt y el canal P06 (P1) antes de hacerlas públicas.
Honeypot (campo señuelo)	Campo oculto en el formulario P06 que los usuarios humanos no ven; si un programa automatizado lo completa, el envío se descarta sin escribir en la base de datos.
HSTS (Strict-Transport-Security)	Cabecera HTTP que obliga al navegador a comunicarse con Farmaps únicamente mediante conexiones cifradas HTTPS.
ITIL	Biblioteca de Infraestructura de Tecnologías de la Información. Marco de buenas prácticas aplicado en Farmaps para estructurar la estrategia, el diseño, la transición, la operación y la mejora continua del servicio.
SRI (Subresource Integrity)	Verificación criptográfica (sha256) que comprueba que la librería externa Leaflet cargada desde unpkg.com no haya sido modificada por terceros.
Tríada CIA	Modelo de seguridad compuesto por Confidencialidad (protección de credenciales y reportes), Integridad (exactitud de precios y bitácora inmutable) y Disponibilidad (continuidad del servicio).

Referencias

Cardozo Prada, J. D. (2026). *Farmaps Manual de usuario*. GitHub. https://github.com/JuanCardozo05/Farmaps/blob/main/DOCUMENTACI%C3%93N/PARCIAL%203/Manual_Usuario.pdf

Foudil, E., & Shafranovich, Y. (2022). *A file format to aid in security vulnerability disclosure (RFC 9116)*. Internet Engineering Task Force (IETF). https://www.rfc-editor.org/rfc/rfc9116

JuanCardozo05. (2026). *Farmaps-Ciberseguridad*[Aplicación web desplegada]. Firebase Hosting. https://farmaps-ciberseguridad.web.app

Scottish Government. (s. f.). *What the service lifecycle is and why it matters*. Service Manual. https://servicemanual.gov.scot/use-itil-service-lifecycle

Universidad Libre. (s. f.). *Guía de trabajo Diseño de un servicio con enfoque ITIL*[Guía de clase]. Facultad de Ingeniería, Programa de Ingeniería de Sistemas.